

Relatório do Trabalho de Grupo

Proposta de controlo de acessos para mini-servidor Linux

Controlo de Acessos para Sistema Web de Gestão de Informação Empresarial em Servidor Linux

Síntese do cenário

Está a ser desenvolvido um sistema web de gestão de informação empresarial, alojado num mini-servidor Linux. Esta aplicação permite à empresa organizar e consultar dados internos, gerir documentos, registos operacionais e informação sensível relacionada com processos de negócio.

O sistema será utilizado por diferentes perfis de utilizadores, com níveis de acesso distintos, incluindo administração do sistema, operação da aplicação, auditoria de registos e consulta limitada de documentação.

Como a aplicação irá lidar com informação crítica da empresa, é essencial implementar um modelo de controlo de acessos seguro, baseado no princípio do menor privilégio, garantindo que cada utilizador apenas acede aos recursos necessários para o desempenho das suas funções.

Perfil, grupos e responsabilidades

Tabela com perfis, grupos, permissões e restrições.

Perfil	Grupo sugerido	Responsabilidade	Permissões necessárias	Permissões a evitar
Administrador do sistema	admin	Faz a gestão geral do servidor, utilizador, serviços, segurança e atualização no sistema	Acesso master via sudo	Uso direto da conta root no dia a dia
Operador web	webops	Atualização da aplicação, deploy de versões e manutenção funcional	Acesso limitado a pasta de aplicação web, com permissão para escrita e leitura dentro desse diretório.	Acesso a ficheiros de sistema e credenciais.

Auditor	auditores	Verificação de logs, auditorias e controlo de conformidade	Acesso apenas a leitura de logs, relatório e documentações. (var/ log)	Alteração do ficheiro, execução e acesso a dados sensíveis.
Visitante técnico	visitors	Consulta de documentação e informação autorizada	Acesso apenas leitura a diretórios públicos.	Acesso a qualquer tipo de escrita, configuração, dados internos ou logs.

Estrutura de diretórios proposta

Estrutura sugerida e explicação.

```

1  /opt/projeto-web/
2  |
3  |--- public/
4  |   |
5  |   |--- index.html
6  |   |--- assets/
7  |   |   |
8  |   |   |--- css/
9  |   |   |--- js/
10 |   |   |--- images/
11 |   |--- uploads/
12 |
13 |--- config/
14 |   |
15 |   |--- application.conf
16 |   |--- database.conf
17 |   |--- logging.conf
18 |   |--- secrets.env
19 |
20 |--- logs/
21 |   |
22 |   |--- access.log
23 |   |--- error.log
24 |   |--- audit.log
25 |
26 |--- docs/
27 |   |
28 |   |--- README.md
29 |   |--- arquitetura.pdf
30 |   |--- procedimentos.md
31 |
32 |--- scripts/
33 |   |
34 |   |--- deploy.sh
35 |   |--- backup.sh

```

A estrutura apresentada na figura anterior demonstra a separação clara entre o código da aplicação, as configurações, logs e documentação, facilitando a gestão de permissões e reduzindo os riscos.

Diretório: /opt/projeto-web/public

Este diretório contém os ficheiros públicos da aplicação web, bem como páginas HTML, ficheiros CSS, JavaScript, imagens e conteúdos enviados pelos utilizadores.

- **Quem pode ler:** Administrador de Sistema e Operador Web.
- **Quem pode escrever:** Administrador de Sistema e Operador Web.
- **Quem não deve ter acesso:** Auditores e Visitantes.
- **Riscos de permissões excessivas:** Alteração não autorizada do conteúdo da aplicação, inserção de código malicioso e comprometimento da integridade do site.

Diretório: /opt/projeto-web/config

Diretório que armazena ficheiros de configuração da aplicação, incluindo configurações da base de dados, parâmetros de funcionamento, configuração de logs e *secrets* da aplicação.

- **Quem pode ler:** Administrador de Sistema e Operador Web (se necessário).
- **Quem pode escrever:** Administrador de Sistema.
- **Quem não deve ter acesso:** Auditor e Visitantes.
- **Riscos de permissões excessivas:** Exposição de credenciais, acesso indevido à base de dados, alteração de configurações críticas e comprometimento de segurança da aplicação.

Diretório: /opt/projeto-web/logs

Este diretório contém os registos de atividade da aplicação, incluindo logs de acesso, erros e auditoria.

- **Quem pode ler:** Administrador de Sistema e Operador Web e Auditor.
- **Quem pode escrever:** Administrador de Sistema e os serviços responsáveis pela geração dos logs.
- **Quem não deve ter acesso:** Visitantes.
- **Riscos de permissões excessivas:** Alteração ou eliminação de evidências, dificuldade em realizar auditorias e ocultação de atividades maliciosas.

Diretório: /opt/projeto-web/docs

Este diretório armazena documentação técnica, manuais, procedimentos operacionais e documentação da arquitetura do sistema.

- **Quem pode ler:** Administrador de Sistema e Operador Web e Auditor.

- **Quem pode escrever:** Administrador de Sistema e Operador Web.
- **Quem não deve ter acesso:** Visitantes.
- **Riscos de permissões excessivas:** Alteração indevida de documentação, introdução de informação incorreta e perda de confiança nos procedimentos documentados.

Diretório: /opt/projeto-web/scripts

Diretório que contém scripts de administração e manutenção, como deploy da aplicação, e backups.

- **Quem pode ler:** Administrador de Sistema e Operador Web.
- **Quem pode escrever:** Administrador de Sistema e Operador Web.
- **Quem não deve ter acesso:** Auditor e Visitantes.
- **Riscos de permissões excessivas:** Execução de comandos não autorizados, alteração de processos de manutenção, interrupção de serviços e escalada de privilégios.

Proposta de permissões

Tabela com permissões e justificação.

Caminho	Grupo	Permissão	Justificação
/opt/projeto-web/	root	750	Proteção da estrutura base do sistema.
/opt/projeto-web/public	root	775	Permite deploy e atualização da aplicação.
/opt/projeto-web/config	root	750	Protege informação sensível e configurações.
/opt/projeto-web/log	root	750	Permite auditoria sem alteração de dados.
/opt/projeto-web/docs	root	755	Acesso controlado à documentação.
/opt/projeto-web/scripts	root	750	Scripts sensíveis para realização de backups.

Regras de acesso remoto por SSH

Perfil	Pode aceder por SSH?	Tipo de autenticação	Justificação
Administrador	Sim	Chaves SSH + sudo	Gestão completa do servidor

Operador web	Sim	Chave SSH individual	Deploy e manutenção da aplicação
Auditor	Sim	Chave SSH (apenas leitura de logs)	Auditoria e controlo
Visitante técnico	Não	Não aplicável	Apenas consulta de documentação local ou externa

Riscos e medidas de mitigação

Risco	Impacto	Medida de mitigação
Contas partilhadas	Falta de rastreabilidade	Criar utilizadores individuais
Uso excessivo de root	Erros críticos no sistema	Utilização de sudo controlado
Permissões excessivas	Exposição de dados sensíveis	Aplicação rigorosa do menor privilégio
Roubo de credenciais SSH	Acesso não autorizado	Uso de chaves SSH e proteção de chaves privadas

Conclusão

O grupo decidiu apresentar uma arquitetura segura de controlo de acessos para um sistema web de gestão de informação empresarial. Foi acordado em separar os perfis, a utilização de grupos Linux e a aplicação do princípio do menor privilégio que permitem garantir a segurança, rastreabilidade e organização.

Com a implementação destas medidas reduz significativamente os riscos de acessos indevidos, perdas de dados e falhas operacionais, assegurando um ambiente estável e adequado para a operação de uma aplicação empresarial crítica.

Grupo: Breakout 15

Discente:

-  Anderson Semedo
-  Constantino Carvalho
-  Veronica Andrade